

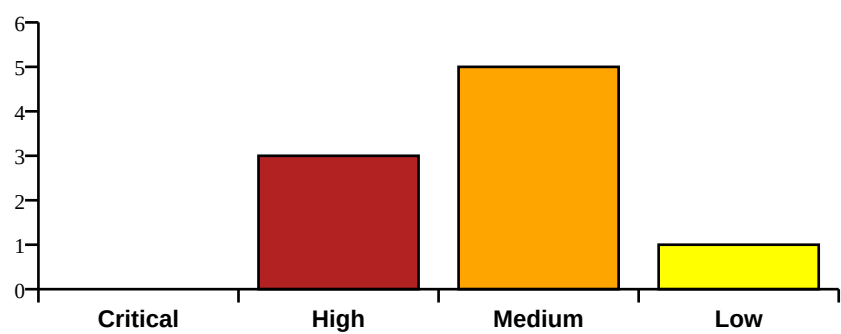
Vulnerability Scan Report

Target URL: http://testphp.vulnweb.com/login.php
Generated (UTC): 2025-12-25 10:31:18Z

Summary

Metric	Count
Total Vulnerabilities	9
Critical Severity	0
High Severity	3
Medium Severity	5
Low Severity	1

Severity Distribution



Detected Vulnerabilities

Type	Location	Evidence / Payload	Severity
XSS	http://testphp.vulnweb.com/login.php		Medium
XSS	http://testphp.vulnweb.com/login.php	alert(1);	Medium
Cryptographic Failure	http://testphp.vulnweb.com/login.php	Issue: Application does not enforce HTTPS	High
Cryptographic Failure	http://testphp.vulnweb.com/login.php	Issue: Strict-Transport-Security header not set	Medium
Insecure Design	http://testphp.vulnweb.com/login.php	Issue: Multiple rapid requests allowed without restriction	High
Insecure Design	http://testphp.vulnweb.com/login.php	Issue: Sensitive endpoint accessible without auth: /admin	High
Insecure Design	http://testphp.vulnweb.com/login.php	Issue: No CAPTCHA or bot protection detected	Low
Insecure Design	http://testphp.vulnweb.com/login.php	Issue: PUT method is enabled	Medium

Insecure Design	http://testphp.vulnweb.com/login.php	Issue: DELETE method is enabled	Medium
-----------------	--------------------------------------	---------------------------------	--------

Activity Log

```
[10:30:32] [+] Loaded 6606 payloads for XSS
[10:30:32] [+] Loaded 4 payloads for SQL Injection
[10:30:32] [+] Loaded 3 payloads for NoSQL Injection
[10:30:32] [+] Loaded 4 payloads for Command Injection
[10:30:33] [+] Found: http://testphp.vulnweb.com/login.php
[10:30:33]
=====
[10:30:33] Starting Vulnerability Scan for http://testphp.vulnweb.com/login.php
[10:30:33]
=====
[10:30:33]
===== Testing for XSS =====
[10:30:33]
[+] Testing form in http://testphp.vulnweb.com/login.php
[10:30:39] [***] Possible XSS in form at: http://testphp.vulnweb.com/login.php
[10:30:39] payload: <svg onload=alert(1)>
[10:30:39] Severity: Medium
[10:30:39] form: <form action="userinfo.php" method="post" name="loginform" >
<table cellpadding="4" cellspacing="1" >
<tr><td>Username : </td><td><input name="uname" size="20" style="width:120px;"
type="text" /></td></tr>
<tr><td>Password : </td><td><input name="pass" size="20" style="width:120px;"
type="password" /></td></tr>
<tr><td align="right" colspan="2" ><input style="width:75px;"
type="submit" value="login" /></td></tr>
</table>
</form>

[10:30:39]
[+] Testing form in http://testphp.vulnweb.com/login.php
[10:30:39] [***] Possible XSS in form at: http://testphp.vulnweb.com/login.php
[10:30:39] payload: <script>alert(1);</script>
[10:30:39] Severity: Medium
[10:30:39] form: <form action="search.php?test=query" method="post" >
<label>search art</label>
<input name="searchFor" size="10" type="text" />
<input name="goButton" type="submit" value="go" />
</form>

[10:30:39]
===== Testing for SQL Injection =====
[10:30:40]
===== Testing for NoSQL Injection =====
[10:30:40]
===== Testing for Command Injection =====
[10:30:40]
===== Testing for Cryptographic Failures =====
[10:30:40]
===== SCANNING http://testphp.vulnweb.com/login.php =====

[10:30:40] [INFO] Checking scheme → http
[10:30:40] [INFO] Initiating TLS handshake
[10:30:45] [SKIP] TLS check skipped → timed out
[10:30:45] [INFO] Checking cipher suite
[10:30:50] [SKIP] Cipher check skipped → timed out
[10:30:50] [INFO] Retrieving TLS certificate
[10:30:55] [SKIP] Certificate check skipped → timed out
[10:30:55] [HTTP] Checking HSTS header
[10:30:56] [HTTP] Response status → 200
[10:30:56] [HTTP] Response headers → {&#x27;Server&#x27;; &#x27;nginx/1.19.0&#x27;;, &#x27;Date&#x27;;
&#x27;Thu, 25 Dec 2025 10:32:18 GMT&#x27;;, &#x27;Content-Type&#x27;; &#x27;text/html; charset=UTF-8&#x27;;
&#x27;Transfer-Encoding&#x27;; &#x27;chunked&#x27;;, &#x27;Connection&#x27;; &#x27;keep-alive&#x27;;,
&#x27;X-Powered-By&#x27;; &#x27;PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1&#x27;;, &#x27;Content-
Encoding&#x27;; &#x27;gzip&#x27;;}
[10:30:56] [SCAN] Checking for weak hashes and sensitive data
[10:30:57]
===== REPORT =====
[10:30:57] - [High] HTTPS not enforced
[10:30:57] - [Medium] HSTS header missing
[10:30:57]
===== SCORE =====
[10:30:57] Crypto Risk Score → 50/100
[10:30:57] Risk Level → MEDIUM
```

```
[10:30:57]
===== Insecure Design Scan =====
[10:30:57]
[+] Checking rate limiting...
[10:30:58] [LOG] GET /login.php → 200 (len=5523, 0.55s)
[10:30:59] [LOG] GET /login.php → 200 (len=5523, 0.57s)
[10:31:00] [LOG] GET /login.php → 200 (len=5523, 0.54s)
[10:31:00] [LOG] GET /login.php → 200 (len=5523, 0.57s)
[10:31:01] [LOG] GET /login.php → 200 (len=5523, 0.55s)
[10:31:02] [LOG] GET /login.php → 200 (len=5523, 0.56s)
[10:31:03] [LOG] GET /login.php → 200 (len=5523, 0.53s)
[10:31:03] [LOG] GET /login.php → 200 (len=5523, 0.56s)
[10:31:04]
[+] Checking authorization design...
[10:31:04] [LOG] GET /admin → 200 (len=262, 0.80s)
[10:31:05] [LOG] GET /admin/login → 404 (len=153, 0.55s)
[10:31:05] [LOG] GET /administrator → 404 (len=153, 0.53s)
[10:31:06] [LOG] GET /manage → 404 (len=153, 0.57s)
[10:31:07] [LOG] GET /user → 404 (len=153, 0.56s)
[10:31:07] [LOG] GET /account → 404 (len=153, 0.55s)
[10:31:08] [LOG] GET /profile → 404 (len=153, 0.57s)
[10:31:08] [LOG] GET /login → 404 (len=153, 0.55s)
[10:31:09] [LOG] GET /register → 404 (len=153, 0.56s)
[10:31:09] [LOG] GET /auth → 404 (len=153, 0.55s)
[10:31:10] [LOG] GET /api → 404 (len=153, 0.53s)
[10:31:10] [LOG] GET /api/admin → 404 (len=153, 0.56s)
[10:31:11] [LOG] GET /api/private → 404 (len=153, 0.54s)
[10:31:12] [LOG] GET /checkout → 404 (len=153, 0.54s)
[10:31:12] [LOG] GET /payment → 404 (len=153, 0.54s)
[10:31:13] [LOG] GET /orders → 404 (len=153, 0.54s)
[10:31:13] [LOG] GET /upload → 404 (len=153, 0.56s)
[10:31:14] [LOG] GET /debug → 404 (len=153, 0.57s)
[10:31:14] [LOG] GET /test → 404 (len=153, 0.53s)
[10:31:15] [LOG] GET /dev → 404 (len=153, 0.56s)
[10:31:15]
[+] Checking business logic trust...
[10:31:15] [LOG] POST /login.php → 200 (len=5523, 0.54s)
[10:31:15] ✓ Business logic validation detected
[10:31:15]
[+] Checking abuse protection (CAPTCHA)...
[10:31:16] [LOG] GET /login.php → 200 (len=5523, 0.54s)
[10:31:16]
[+] Checking HTTP method exposure...
[10:31:17] [LOG] PUT /login.php → 200 (len=5523, 0.56s)
[10:31:17] [LOG] DELETE /login.php → 200 (len=5523, 0.54s)
[10:31:18] [LOG] TRACE /login.php → 405 (len=157, 0.56s)
```